

Partial Exam 24/10/2022

1 Part 1, Mandatory

Honor Code
I have read and understood the rules (summary: only course resources, no communication with others) and follow them.

☐ Yes

☐ No

T/F statements [for E]

1. A burglar alarm is the real-world equivalent of an intrusion detection system.
2. A packet filtering firewall filters out specific content from network packets.
3. Some DOS attacks can be countered by designing the system to use multiple service providers for the same functionality.
4. Privacy is a synonym for confidentiality.
5. Allowing students write access to all canvas pages in a course goes against the principle of economy of mechanism.
6. For message authentication, the content of the message does not have to be encrypted.

Assignment: For each of the statements, classify them as true or false and explain your reasoning.

2 Part 2, Optional, for higher grades

1 Hash functions. [A, C, E]

Let x be a message and $x[i]$ be the i-th block of 128 bits of x (e.g., if x is $128 * 3 - 2 = 382$ bit long, $x = x[0] \mid x[1] \mid x[2]$ where the last block is only 126 bits and $\mid$ is block concatenation). Let $pad(x)$ be the padding of x: that is $pad(x) = x$ followed by 0s to fill the last **even** block of x (e.g., if x is $128 * 3 - 2 = 382$ bit long, $pad(x) = x[0] \mid x[1] \mid x[2]]$ followed by 128+2 0s)..

Let $H(x) = AES_d(pad(x)[0], pad(x)[1]) \oplus AES_d(pad(x)[2], pad(x)[3]) \ldots$, where $AES(a, b)$ is encryption of block a using key b and $\oplus$ is bitwise xor.

Remark In AES, both $decrypt(encrypt(m, k), k)$ and $encrypt(decrypt(m, k), k)$ are equal to m.

Assignment (requirements for higher grades are cumulative here)

E A hash function turns input of arbitrary length into output of fixed length (i.e., 128 bits in this case); H is an example of a hash function. To make a hash function **secure**, additional properties are needed. Define these additional properties.

C Is H a secure hash function? For each of the properties that are needed to make a hash function secure, disprove or argue why they hold.

A If H is not secure, describe the consequences of using H as a hash function for an application of your choice. If H is secure, give an example of an application it could be used for.

2 One scenario, several facets [A, C, E] (Grade = highest common level across the facets)

The Never-Ending Notes Company is a startup providing a single service called the Never-Ending Notes (NEN). The idea of NEN is that the service keeps all of your notes and synchronizes them across all your devices. So if you take notes on your laptop running Linux, those same notes will later be available on your iPhone.
NEN Company realized, however, that none of their employees are skilled in cybersecurity. They are aiming high with their product, so they naturally didn't want to settle for anything less than to hire the best of the best to do the security of the NEN product. They hired you, don't let them down!
You received the following brief about the product design:

> NEN Key Ideas
>
> - It must be super easy to set up device syncing.
> - Data is stored in the cloud. This way we can have a subscription-based service.
> - We must support computers, smartphones, tablets.
> - Computers: we have a syncing service running in the background, so that users can write in their normal text editors.
> - Smartphones and tablets: we have an app that does both text editing and syncing.

2a Authentication and access control

The NEN Company gives you the following design proposal that they want you to evaluate for them.

Threat: A NEN Company employee might try to access users' notes to find some sensitive data. For instance, a therapist might use the note taking service to track notes about their patients.

Mitigation: We have three proposed solutions to deal with the threat.

1. We encrypt each users data. The key is derived from the user's password. This way, the insider must know the password or be able to guess it to gain access.
2. We let each client have a randomly generated encryption/decryption key (not based on the password). The clients encrypt the data before sending it to the NEN servers. No one can access the data without that cryptographic key.

   When adding new devices, they must sync the key from an already existing device.

   We can't recover any data if that key is lost. Backing it up securely is our only option.
3. We use several forms of separation of duties. One separation of duties: all user data is encrypted when in storage, it is decrypted by another system for the user before being sent to the user. Another separation of duties: all access to the storage and decryption systems are logged, logs are stored in other systems managed by different people. This means that the attacker must collude with several other people to get access to decrypted user data.

Assignment: Compare the different suggestions, analyse each and suggest which to pick and if you would recommend any amendment to the solution.

2b Intrusion detection and prevention

The NEN Company gives you the following design proposal that they want you to evaluate for them.

Threat: A hacker might try to access the system's administrative user interface from the Internet.

Mitigation: We have these proposed solutions to deal with the threat.

1. We set up the firewall to block any connections to the administrative user interface from outside our network. This way, that interface will be completely unreachable from the Internet. We can still use a VPN to access it when working remotely.
2. We have people working remotely, so we can't deny all access to the administrative interface from outside. We allow certain source addresses to access the interface through whitelisting.
3. We allow any connection to the administrative interface from the outside, but we set up an intrusion detection system to monitor for possible attacks and blocks anything that comes up.

Assignment: Compare the different suggestions, analyse each and suggest which to pick and if you would recommend any amendment to the solution.

2c Denial of Service

Threat: The server running the NEN service could be targeted by an ICMP flood attack. **Mitigation**: NEN have no proposals and ask you. **Assignment**: Which countermeasure can be used to prevent or mitigate this attack and who is in charge of it?